

CloudTrail: the record of what happened

The four event types, the three places the record lives, and the questions CloudTrail cannot answer.

CloudTrail records **that the call was made**.
It does not record what the data said.

The shape of a CloudTrail record

- ◆ **userIdentity** – who. Type of Root, IAMUser, AssumedRole or AWSService. **sessionContext** names the role and session.
- ◆ **eventName** and **eventSource** – what was called, against which service.
- ◆ **errorCode** – present only when the call failed. **AccessDenied** starts most authorisation investigations.
- ◆ **sourceIPAddress** and **userAgent** – where from, and with what.
- ◆ SCS-C03 **removed** log format as a stated skill. Know these four; skip the schema.

ON THE EXAM

A denied call is still a logged call. That is why CloudTrail detects, not just audits.

Four event types, and only one is on by default

EVENT TYPE	RECORDS	DEFAULT
Management	Control plane. CreateBucket, AssumeRole, ConsoleLogin	On. First copy free
Data	Data plane. S3 GetObject, Lambda Invoke, DynamoDB items	OFF. Charged
Network activity	API calls arriving through your VPC endpoints	OFF. Opt in per service
Insights	Unusual rates of write calls, or unusual error rates	OFF. Charged

ON THE EXAM

Object read and nobody knows who? Data events were never enabled.

Data events and network activity events

- ◆ **Data events** use advanced event selectors. Scope to a prefix or resource ARN, not the whole bucket.
- ◆ **Network activity events** answer what nothing else can: **which calls your VPC endpoint policy denied**.
- ◆ You can log **accessDenied calls only**. Cheap, and it is the signal a data perimeter needs.
- ◆ GA February 2025. Originals were S3, EC2, KMS, Secrets Manager and CloudTrail; the list has grown.
- ◆ July 2026: selectors can filter by **userIdentity**, so you record outsiders and not yourself.

ON THE EXAM

Data events: who touched the object. Network activity events: who was turned away.

Three places the record can live

WHERE	HOLDS	QUERY WITH
Event history	Last 90 days, management events only, per Region, free	Console filters. No SQL, cannot be extended
Trail to S3	Whatever you select, for as long as you keep the objects	Athena, or ship it to a SIEM
CloudTrail Lake	Up to 3,653 days in an immutable event data store	SQL, in place, no pipeline to build

ON THE EXAM

Event history is a convenience, not a retention strategy. Its 90 days is fixed and there is no setting to change it.

Trail to S3, or CloudTrail Lake?

CHOOSE A TRAIL TO S3 WHEN

The logs feed something else

- A SIEM or Security Lake is the real consumer
- You want lifecycle, Object Lock and Glacier pricing
- Cheapest place to park high-volume data events
- An auditor wants the logs as files

CHOOSE CLOUDTRAIL LAKE WHEN

The logs are the investigation

- Analysts need SQL over years of activity, now
- Config items and Audit Manager evidence in one store
- Retention to 10 years, immutable, no pipeline
- Non-AWS and on-premises events alongside AWS

THE TIEBREAKER

Building a pipeline is the signal for a trail. Wanting to ask questions today is the signal for Lake.

Organization trails

- ◆ Created in the **management account** or by a **delegated administrator**. Covers every current and future member account.
- ◆ Member accounts can see it. They cannot modify or delete it. That is the point.
- ◆ One bucket, prefixed by account ID and Region, in a separate **log archive account**.
- ◆ New accounts are covered automatically. A new **Region** only if the trail is **multi-Region**.
- ◆ Lake has the same pattern: an **organization event data store**.

ON THE EXAM

Delegated administrator recurs whenever security must run from a security account.

How log file integrity validation actually works

01

Hash

CloudTrail SHA-256 hashes each log file as it is delivered.

02

Digest

Every hour it writes a digest file listing that hour's files and hashes.

03

Sign

The digest is signed with SHA-256 with RSA, using a private key AWS holds.

04

Chain

Each digest references the previous digest's hash, forming a chain.

05

Validate

aws cloudtrail validate-logs re-computes and checks the chain.

ON THE EXAM

It proves nothing was altered or deleted since delivery. It does not stop anyone altering or deleting. For that you need Object Lock.

Encrypting the record

- ◆ **Trails:** SSE-S3 by default. Point at a **customer managed KMS key** for SSE-KMS when a control demands it.
- ◆ The key policy must let **cloudtrail.amazonaws.com** call **GenerateDataKey**, and readers call **Decrypt**.
- ◆ Encrypt without decrypt is a real failure mode. Auditors receive files they cannot open.
- ◆ **Lake:** also SSE-S3 by default. Once a KMS key is associated it **cannot be removed or changed**.
- ◆ **aws:SourceArn and aws:SourceAccount are not supported** on event data store key policies. Trails support them.

ON THE EXAM

The confused-deputy condition keys do not exist on Lake key policies.

From an API call to somebody being woken up

01

Call

A principal calls DisableKey on a production KMS key.

02

Trail

The trail delivers to S3 and to a CloudWatch log group.

03

Filter

A metric filter matches eventName = DisableKey and increments a metric.

04

Alarm

A CloudWatch alarm on that metric breaches at 1 and fires SNS.

05

Act

Or skip the metric: an EventBridge rule on the CloudTrail event invokes Lambda.

ON THE EXAM

S3 alone is storage. If a question wants alerting, look for CloudWatch Logs or EventBridge in the answer, not just a trail.

What CloudTrail will not tell you

- ◆ **What was in the object.** CloudTrail saw GetObject. Macie sees the card numbers.
- ◆ **What happened inside the instance.** No processes, no shells. That is GuardDuty Runtime Monitoring.
- ◆ **Traffic that is not an API call.** A port scan is VPC Flow Logs, not CloudTrail.
- ◆ **What the configuration looks like now.** CloudTrail streams changes; AWS Config holds state.
- ◆ **Everything, instantly.** Delivery takes about five minutes. Near real time, not real time.

ON THE EXAM

Five gaps, five services. Most distractors offer a gap as if CloudTrail closed it.

A media company stores unreleased film assets in an S3 bucket. A multi-Region organization trail has been running for two years, delivering management events to a log archive account.

An asset leaks before its release date. The security team opens Athena over the trail logs and finds the bucket's PutBucketPolicy and PutBucketAcl events, but no record of any object being read. The bucket has never had server access logging enabled.

Why is there no record of the object being read?

- ☐ A Organization trails record management events for member accounts but not data events
- ☐ B S3 data events are not logged unless explicitly enabled, and they were not
- ☐ C The 90-day Event history limit has expired for those events
- ☐ D GetObject calls through a VPC endpoint are recorded only as network activity events

◆ PAUSE AND DECIDE

Why is there no record of the object being read?

A Organization trails record management events but not data events

Tempting, and false. An organization trail can carry data events perfectly well. The limitation is not the organization scope, it is that nobody selected them.

C The 90-day Event history limit has expired

Confuses two things. Event history is the free console view. These logs are in S3 via a trail, where retention is however long you keep the objects.

B S3 data events are not logged unless explicitly enabled, and they were not

Correct. Data events are off by default on every trail. Two years of faithful logging captured every policy change and no reads.

D GetObject through a VPC endpoint is only a network activity event

Network activity events are also off by default, so this would not produce records either. And the scenario never mentions a VPC endpoint.

THE SIGNAL

The deciding words are 'management events'. The trail was described precisely, and the description excluded the thing they needed.

A financial services firm is preparing for an external audit. The auditor requires evidence that three years of CloudTrail logs have not been altered or deleted since they were written.

The logs are delivered by an organization trail to a bucket in a log archive account. The bucket has versioning enabled and is encrypted with a customer managed KMS key. A small number of engineers hold s3:DeleteObjectVersion on the bucket.

What should the firm implement to satisfy the auditor?

- ☐ A Rely on the customer managed KMS key, since encrypted objects cannot be modified
- ☐ B Enable CloudTrail log file integrity validation and apply S3 Object Lock in compliance mode
- ☐ C Enable MFA delete on the bucket and remove s3:DeleteObjectVersion from the engineers
- ☐ D Copy the logs into a CloudTrail Lake event data store with a ten-year retention period

◆ PAUSE AND DECIDE

What should the firm implement to satisfy the auditor?

- A

 Rely on the customer managed KMS key
Encryption protects confidentiality, never integrity. Anyone with permission to write the object can overwrite it, encrypted or not.
- B

 Log file integrity validation plus S3 Object Lock in compliance mode
Correct. Validation proves nothing changed. Object Lock in compliance mode means nobody, including the root user, can delete a version before its retention date.
- C

 MFA delete and remove the delete permission
A real improvement, and it would prevent future deletion. It offers the auditor no evidence about the last three years, which is what was asked for.
- D

 Copy into a CloudTrail Lake event data store
Lake stores are immutable, so this is the most tempting wrong answer. But copying creates a new artefact. It cannot prove the source was untouched before the copy.

THE SIGNAL

The auditor asked for two things: proof nothing changed, and assurance nothing can change. Detection and prevention are different controls.

A pharmaceutical company runs a strict data perimeter. Research data sits in S3, reachable only through a gateway VPC endpoint whose endpoint policy restricts access to principals in the organization.

The security team wants to know whenever a principal from outside the organization attempts to reach that data through the endpoint and is refused. Volume matters: the endpoint carries millions of legitimate calls a day and the team has a tight logging budget.

What should the security team configure?

- ☐ A Enable VPC Flow Logs on the subnets and alert on rejected flows
- ☐ B Enable S3 data events on the bucket and filter for AccessDenied in Athena
- ☐ C Enable CloudTrail network activity events for S3, logging accessDenied calls only
- ☐ D Enable CloudTrail Insights to detect the unusual error rate

◆ PAUSE AND DECIDE

What should the security team configure?

- A

 VPC Flow Logs, alerting on rejected flows
Flow Logs see packets, not API calls. An endpoint policy denial is an application-layer refusal; the packets were accepted. There is no REJECT to alert on.
- B

 S3 data events, filtered for AccessDenied
Would work, and would log millions of successful calls to find a handful of failures. The budget constraint rules it out, and it misses denials the endpoint policy stopped before S3.
- C

 Network activity events for S3, accessDenied only
Correct. This is the only source that records what a VPC endpoint policy refused, and the accessDenied-only setting means you pay for the signal and not the noise.
- D

 CloudTrail Insights for the unusual error rate
Insights detects anomalous rates of management calls. A steady trickle of denials is not an anomaly, and it tells you a rate changed rather than who was refused.

THE SIGNAL

Two phrases decide it: 'through the endpoint' and 'is refused'. Only network activity events see both.

A retailer has 200 accounts in AWS Organizations. After an incident where an investigation took nine days, the CISO wants analysts able to run ad hoc queries across seven years of API activity for every account, without waiting on the data team.

The existing organization trail already delivers to S3 in a log archive account. The data team is at capacity and has said it cannot take on new pipelines this year.

What should the retailer implement with the LEAST operational overhead?

- ☐ A Increase CloudTrail Event history retention to seven years in every account
- ☐ B Build a Glue crawler over the trail bucket and give analysts Athena access
- ☐ C Create an organization event data store in CloudTrail Lake
- ☐ D Stream the trail logs to an Amazon OpenSearch Service domain in the security account

◆ PAUSE AND DECIDE

What should the retailer implement with the LEAST operational overhead?

- A** Increase Event history retention to seven years

Not possible. Event history is fixed at 90 days with no setting to change it. Any option offering to extend it is a distractor.
- B** Glue crawler over the trail bucket plus Athena

It works, and it is a pipeline with a schema, partitions and a crawler to maintain. The data team was explicitly ruled out as an owner.
- C** An organization event data store in CloudTrail Lake

Correct. One store across all 200 accounts, SQL in place, retention to 3,653 days, and existing S3 logs can be imported so history is not lost.
- D** Stream to an OpenSearch Service domain

Powerful and the heaviest option here. A domain is capacity you size, patch, scale and pay for continuously, and seven years of 200 accounts is a large cluster.

THE SIGNAL

'LEAST operational overhead' plus 'the data team cannot take on new pipelines' is the same instruction written twice. Both point away from anything you have to run.

Five things to carry forward

- ◆ **Management events are on. Data and network activity events are not.** Most 'why is there no record' questions end here.
- ◆ **Event history is 90 days and cannot be extended.** Any option offering to extend it is wrong.
- ◆ **Integrity validation detects tampering. Object Lock prevents it.** Read whether the question wants evidence or prevention.
- ◆ **Network activity events are the only record of a VPC endpoint policy denial.** Log accessDenied only and it is cheap.
- ◆ **A trail to S3 is storage.** Alerting needs CloudWatch Logs and a metric filter, or EventBridge.

ON THE EXAM

Next: CloudWatch Logs, metric filters and alarms – the machinery that turns this record into someone's phone ringing.